

Manual 45 — Enterprise Compliance Training

Capstone

Controlled language: English. This capstone is project-authored training material that integrates the published GRC Practical Manuals into an enterprise implementation exercise. It does not reproduce protected standards text and does not replace legal, regulatory, audit, or certification advice.

Chapter 01 — Capstone Purpose

Define the enterprise scenario, learning objectives, decision rights, evidence expectations, and completion criteria. The learner must demonstrate how governance, risk, compliance, cybersecurity, privacy, resilience, third-party risk, cloud, OT, AI, and assurance disciplines operate as one system.

Chapter 02 — Enterprise Scenario

Establish a multinational enterprise with regulated operations, cloud services, AI-enabled processes, critical suppliers, personal data, financial reporting obligations, and operational technology. Record assumptions and explicitly distinguish facts from scenario choices.

Chapter 03 — Governance Charter

Create a governance charter covering board oversight, executive accountability, policy ownership, risk acceptance authority, escalation, exceptions, and independent assurance. Define measurable outcomes rather than framework labels alone.

Chapter 04 — Regulatory Applicability

Build an applicability register linking jurisdictions, business activities, data classes, sectors, contracts, and regulated systems to relevant obligations. Capture applicability rationale, owner, review date, and authoritative source.

Chapter 05 — Control Architecture

Design a common control architecture that separates control objective, control activity, implementation, evidence, owner, frequency, test method, and mapped obligations. Avoid one-to-one framework duplication when one effective control satisfies several requirements.

Chapter 06 — Risk Taxonomy

Create an enterprise risk taxonomy spanning cyber, privacy, AI, resilience, financial reporting, supplier, operational, legal, and strategic risk. Define consistent likelihood, impact, velocity, exposure, and residual-risk conventions.

Chapter 07 — Asset and Service Inventory

Establish authoritative inventories for business services, applications, infrastructure, data, AI systems, OT assets, vendors, identities, and critical dependencies. Require ownership and lifecycle status for every in-scope object.

Chapter 08 — Data Governance

Classify data, define lawful and business purposes, retention, minimization, residency, access, sharing, disposal, and lineage expectations. Link data controls to systems, vendors, AI uses, privacy rights, and evidence.

Chapter 09 — Identity and Access

Define identity lifecycle, privileged access, authentication, federation, segregation of duties, recertification, service identities, emergency access, and evidence retention. Include human and non-human identities.

Chapter 10 — Secure Configuration

Establish approved baselines for endpoints, servers, cloud, network, databases, SaaS, OT, and security tooling. Define deviation handling, monitoring, rollback, and configuration evidence.

Chapter 11 — Vulnerability Management

Define discovery, validation, prioritization, remediation, exception, compensating control, and verification processes. Risk prioritization must account for exploitability, exposure, asset criticality, business impact, and threat context.

Chapter 12 — Secure Development

Integrate secure requirements, threat modeling, code review, dependency governance, testing, release approval, provenance, secrets handling, and vulnerability response into software and AI-enabled development lifecycles.

Chapter 13 — AI Governance

Inventory AI use cases and models, classify risk, document intended purpose, human oversight, data provenance, evaluation, security, privacy, transparency, monitoring, change control, incident handling, and retirement.

Chapter 14 — AI Security

Address prompt injection, unsafe tool use, data leakage, model and supply-chain risk, retrieval integrity, agent permissions, logging, guardrails, red teaming, abuse cases, and fail-safe behavior proportionate to risk.

Chapter 15 — Privacy Engineering

Translate privacy obligations into technical and operational controls for notice, choice, rights handling, minimization, purpose limitation, retention, security, processor governance, cross-border transfer, and automated decisions.

Chapter 16 — Third-Party Risk

Define intake, inherent risk, due diligence, contracting, security/privacy requirements, monitoring, issue management, concentration risk, fourth-party visibility, termination, and evidence requirements for suppliers.

Chapter 17 — Cloud Governance

Define landing-zone controls, account/subscription governance, network boundaries, IAM, encryption, logging, key management, posture management, backup, resilience, workload ownership, and shared-responsibility evidence.

Chapter 18 — OT and ICS Security

Separate safety and operational constraints from ordinary IT assumptions. Address zoning, remote access, asset visibility, change control, monitoring, vendor access, backup, recovery, incident coordination, and compensating controls.

Chapter 19 — Detection and Logging

Define security, privacy, AI, application, cloud, identity, and OT logging requirements. Establish ownership, retention, integrity, time synchronization, detection logic, alert quality, and evidence preservation.

Chapter 20 — Incident Response

Create integrated incident classification, command, investigation, containment, eradication, recovery, legal/privacy assessment, regulatory notification, communications, evidence preservation, lessons learned, and corrective-action tracking.

Chapter 21 — Business Continuity

Map critical services to recovery objectives, dependencies, people, facilities, suppliers, technology, data, and alternate processes. Test realistic disruption scenarios and document gaps through remediation closure.

Chapter 22 — Disaster Recovery

Define technology recovery tiers, backup integrity, restoration procedures, alternate environments, dependencies, recovery validation, cyber-recovery considerations, and evidence demonstrating tested recoverability.

Chapter 23 — Financial and IT Controls

Integrate IT general controls, access, change, operations, interfaces, reports, automated controls, evidence, deficiency evaluation, management review, and remediation with broader enterprise GRC governance.

Chapter 24 — Compliance Operations

Design obligation intake, control mapping, testing calendar, evidence collection, issue workflow, regulatory change management, policy lifecycle, attestation, exception handling, and management reporting.

Chapter 25 — Assurance and Audit

Define first-line monitoring, second-line challenge, internal audit independence, external assurance support, sampling, test design, workpapers, evidence sufficiency, issue rating, remediation validation, and closure authority.

Chapter 26 — Metrics and KRIs

Select outcome-oriented metrics for risk reduction, control performance, exposure, exceptions, remediation aging, incident trends, supplier risk, AI risk, privacy operations, resilience, and audit findings. Define thresholds and escalation.

Chapter 27 — Executive Reporting

Build concise board and executive reporting that distinguishes exposure, control effectiveness, significant change, accepted risk, overdue remediation, emerging risk, incidents, regulatory developments, and decisions required.

Chapter 28 — Evidence Management

Define evidence source, owner, frequency, immutable reference, collection method, retention, access, quality checks, and linkage to controls and tests. Evidence must demonstrate operation, not merely policy existence.

Chapter 29 — Integrated Exercise

Run a scenario combining a supplier compromise, cloud exposure, AI-enabled workflow, privacy impact, operational disruption, and potential disclosure obligation. Require coordinated decisions across business, legal, security, privacy, resilience, and audit.

Chapter 30 — Management Response

Document executive decisions, risk acceptance or remediation, accountable owners, deadlines, resource commitments, communication strategy, and follow-up validation. Unresolved disagreements must be escalated through defined governance.

Chapter 31 — Capstone Assessment

Assess completeness, traceability, control design, evidence quality, decision quality, risk reasoning, cross-functional coordination, and ability to distinguish requirement from interpretation. Require remediation for material deficiencies.

Chapter 32 — Publication and Continuous Improvement

Freeze the final capstone package only after predecessor publication state, source verification, trilingual parity, artifact integrity, document/render QA, accessibility review, repository security controls, provenance, and final human release approval are satisfied. Maintain a change log and revalidate the capstone when upstream manuals materially change.